

Security+ 3.2 · Port Security

Mestre CyberSec · Aula 3.2 — Port Security (3:50) · [Assistir Vídeo no YouTube](#) ↗ · Treino Interativo: edusouzamarques.github.io/cybersec

Resumo Executivo da Aula: 802.1X: autentica o USUÁRIO/máquina antes de dar acesso à rede via switch. RADIUS centraliza o AAA. Sem 802.1X, qualquer um conecta e tem acesso. NAC (Network Access Control) = 802.1X + postura (antivirus/patch health).

💡 Highlights que a prova CompTIA cobra

- 802.1X: autentica ANTES de dar acesso à porta do switch
- RADIUS: o backend central de AAA
- NAC: 802.1X + checagem de saúde (antivirus, patch)

🎯 Dicas de Prova & Cenários Típicos da Banca

- 'requires authentication before network access'=802.1X

Por que este aprofundamento é cobrado na prova?: O vídeo resume os tópicos práticos, mas o exame CompTIA SY0-701 cobra discernimento técnico rigoroso sobre as tecnologias e protocolos específicos desta seção:

• IEEE 802.1X (802.1X)

Padrão IEEE para controle de acesso à rede baseado em porta que autentica o suplicante antes de conceder acesso a uma porta de switch ou rede sem fio.

⚠ **Armadilha CompTIA:** Se a questão disser 'requires authentication before network access' ou 'port-based access control', a resposta é 802.1X; não confunda com MAC filtering, que apenas filtra endereços.

• Protocolo de Autenticação Extensível (EAP)

Framework de autenticação usado pelo 802.1X para suportar vários métodos de autenticação, como certificados ou usuário/senha.

⚠ **Armadilha CompTIA:** EAP é o método de autenticação dentro do 802.1X; não fornece criptografia por si só. EAP-TLS usa certificado, PEAP usa túnel TLS.

• Serviço de Autenticação Remota de Usuário Discado (RADIUS)

Protocolo de servidor AAA centralizado comumente usado com 802.1X para autenticar, autorizar e contabilizar acesso à rede.

⚠ **Armadilha CompTIA:** RADIUS é o backend central de AAA; quando a questão mencionar 'centralized authentication' com 802.1X, pense RADIUS. Não confunda com TACACS+, que é mais usado para administração de dispositivos Cisco.

• Autenticação, Autorização e Contabilização (AAA)

Framework de segurança que verifica identidade (autenticação), concede permissões (autorização) e registra atividades (contabilização).

⚠ **Armadilha CompTIA:** RADIUS centraliza AAA. Não confunda autenticação (quem é) com autorização (o que pode fazer) e accounting (registro/auditoria).

• Controle de Acesso à Rede (NAC)

Abordagem de segurança que combina autenticação 802.1X com avaliação de postura para garantir que dispositivos estejam em conformidade antes do acesso à rede.

⚠ **Armadilha CompTIA:** NAC = 802.1X + health/posture check. Se a questão exigir checar antivírus ou patches antes de permitir acesso, a resposta é NAC.

• Avaliação de Postura (N/A)

Verificação de saúde realizada pelo NAC para validar conformidade do endpoint, como status do antivírus, nível de patch e configurações de firewall antes de conceder acesso.

⚠ **Armadilha CompTIA:** Gatilho: 'antivirus/patch health' ou 'compliance check' antes do acesso = posture assessment, parte do NAC.

• Funções do 802.1X (Suplicante, Autenticador, Servidor de Autenticação) (802.1X Roles)

No 802.1X, o suplicante é o cliente que solicita acesso, o autenticador é o switch/AP que controla a porta, e o servidor de autenticação é tipicamente o RADIUS que valida as credenciais.

⚠ **Armadilha CompTIA:** Diferencie: supplicant = cliente; authenticator = switch; authentication server = RADIUS. O switch não valida credenciais; ele repassa ao RADIUS.

• Segurança de Porta (Limitação de Endereço MAC) (N/A)

Recurso de switch que restringe quais endereços MAC podem usar uma porta, muitas vezes via sticky MAC, limites de MAC e modos de violação (shutdown, restrict, protect).

⚠ **Armadilha CompTIA:** Port security com MAC filtering não autentica usuário; apenas limita MACs. 802.1X autentica antes do acesso. Violation modes: shutdown derruba a porta, restrict descarta e gera log, protect descarta silenciosamente.

✓ Perguntas de Treino Comentadas (10 Questões de Cenários Reais)

Cenários autênticos alinhados aos objetivos do exame. O gabarito com análise completa dos distratores encontra-se ao final.

QUESTÃO 1 · CENÁRIO DE EXAME

Um hospital regional habilitou 802.1X em todos os switches de acesso cabeados. Quando uma enfermeira conecta um notebook a um ponto de rede, a porta permanece bloqueada até que o notebook apresente credenciais, e o switch então repassa essa troca ao servidor RADIUS antes de liberar a porta. Qual papel do 802.1X o switch está desempenhando nesse desenho?

- A) Supplicant (suplicante)
- B) Autenticador
- C) Servidor de autenticação
- D) Autoridade de certificação

QUESTÃO 2 · CENÁRIO DE EXAME

Uma empresa opera 300 switches de acesso em 12 locais e deseja um único repositório autoritativo de credenciais de usuários, política de acesso consistente e registros centralizados de todas as autenticações. Qual solução atende melhor a esses requisitos?

- A) Criar contas de usuário locais idênticas na configuração de cada switch
- B) Implantar um servidor RADIUS consultado por todos os switches para os serviços AAA
- C) Habilitar o aprendizado de endereços MAC sticky em todas as portas de acesso
- D) Colocar cada departamento em sua própria VLAN com uma sub-rede dedicada

QUESTÃO 3 · CENÁRIO DE EXAME

O notebook de um prestador de serviços autentica com sucesso na LAN corporativa, mas a solução de NAC detecta que o sistema operacional está sem patches críticos e que as assinaturas de antivírus estão três meses desatualizadas. O notebook é colocado em uma VLAN com acesso apenas aos servidores de atualização de patches e antivírus. Qual recurso do NAC produziu esse resultado?

- A) Contabilização RADIUS
- B) Segurança de porta com endereços MAC sticky
- C) Avaliação de postura (integridade do host)
- D) Autenticação mútua EAP-TLS

QUESTÃO 4 · CENÁRIO DE EXAME

Durante uma inspeção, um técnico descobre que alguém conectou um mini-switch não gerenciado a um ponto de rede da sala de conferências e ligou quatro notebooks pessoais por meio dele, todos obtendo endereços IP corporativos. Qual controle impediria isso de forma mais direta na camada de acesso?

- A) Habilitar EAP-TLS no supplicant de cada endpoint corporativo
- B) Configurar segurança de porta com um número máximo de endereços MAC nas portas de acesso
- C) Implantar contabilização RADIUS em todos os switches da camada de acesso
- D) Atribuir todos os pontos de rede da sala de conferências à VLAN de convidados

QUESTÃO 5 · CENÁRIO DE EXAME

Uma instituição financeira exige que tanto o dispositivo do usuário quanto o servidor de autenticação provem suas identidades com certificados digitais X.509, e que nenhuma senha trafegue pela rede durante a autenticação. Qual método EAP a equipe de segurança deve escolher?

- A) EAP-TLS
- B) EAP-MD5
- C) PEAP
- D) LEAP

QUESTÃO 6 · CENÁRIO DE EXAME

Depois que um usuário conclui com sucesso a autenticação 802.1X, o servidor RADIUS retorna atributos que colocam a sessão na VLAN de Contabilidade e aplicam uma lista de controle de acesso permitindo apenas o aplicativo financeiro. Qual função AAA esses atributos retornados implementam?

- A) Autenticação
- B) Contabilização
- C) Autorização
- D) Auditoria

QUESTÃO 7 · CENÁRIO DE EXAME

Um engenheiro de rede está solucionando problemas em uma implantação 802.1X cabeada. O supplicant do cliente e o switch trocam quadros EAP antes que o switch encaminhe qualquer coisa ao servidor RADIUS. Qual protocolo transporta esses quadros EAP no enlace entre o supplicant e o autenticador?

- A) EAPOL
- B) RADIUS
- C) TACACS+
- D) LDAP

QUESTÃO 8 · CENÁRIO DE EXAME

Um atacante copia o endereço MAC de uma estação de trabalho autorizada para um notebook malicioso e se conecta a uma porta de acesso que tem aprendizado de MAC sticky habilitado. O switch aceita a conexão e o atacante alcança recursos internos. Qual controle impediria melhor esse ataque no futuro?

- A) Aumentar o limite máximo de endereços MAC nas portas de acesso
- B) Habilitar o aprendizado de endereços MAC sticky em mais portas
- C) Configurar DHCP snooping nos switches de acesso
- D) Implantar 802.1X com autenticação baseada em certificados nas portas de acesso

QUESTÃO 9 · CENÁRIO DE EXAME

Uma organização regulamentada precisa mostrar aos auditores um registro de cada usuário que se conectou à rede cabeada, o switch e a porta específicos utilizados e o horário de início e fim de cada sessão. Qual componente AAA fornece essa evidência?

- A)** Avaliação de postura
- B)** Contabilização
- C)** Autenticação
- D)** Autorização

QUESTÃO 10 · CENÁRIO DE EXAME

Uma planta industrial possui câmeras IP e impressoras de etiquetas legadas que não têm supplicant 802.1X e não podem ser modificadas. A equipe de segurança ainda quer que esses dispositivos sejam autenticados e colocados em uma VLAN restrita, em vez de ficarem em portas totalmente abertas. Qual abordagem é mais apropriada?

- A)** Desabilitar o 802.1X em todas as portas de acesso da planta
- B)** Configurar MAC Authentication Bypass nas portas de switch usadas por esses dispositivos
- C)** Instalar um certificado de cliente EAP-TLS no firmware dos dispositivos
- D)** Definir o número máximo de endereços MAC da porta de segurança de porta como zero

GABARITO COMENTADO COM ANÁLISE DE DISTRATORES

Questão 1: Alternativa B — Autenticador

No 802.1X a porta do switch atua como autenticador. Ela mantém a porta em estado não autorizado (permitindo apenas tráfego EAPOL) até que o supplicant — o software cliente no endpoint — prove sua identidade; em seguida o switch reencapsula a troca EAP em pacotes RADIUS na direção do servidor de autenticação e libera ou restringe a porta conforme a decisão retornada. O autenticador apenas repassa as credenciais; ele não as valida por conta própria, e não é o supplicant do endpoint nem uma autoridade de certificação.

Questão 2: Alternativa B — Implantar um servidor RADIUS consultado por todos os switches para os serviços AAA

O RADIUS centraliza Autenticação, Autorização e Contabilização (AAA) em implantações 802.1X. Todos os switches (autenticadores) encaminham a troca de credenciais a um servidor autoritativo único, de modo que a política é aplicada de forma consistente e os registros de contabilização ficam em um repositório auditável. Contas locais em switches não escalam, não podem ser auditadas centralmente e não oferecem autenticação 802.1X por usuário; MAC sticky e segmentação por VLAN resolvem problemas diferentes.

Questão 3: Alternativa C — Avaliação de postura (integridade do host)

A avaliação de postura é a função do NAC que inspeciona o estado de integridade do endpoint — nível de patches, atualidade do antivírus/EDR, status do firewall, criptografia de disco — após a verificação da identidade, e então aplica o resultado, normalmente colocando dispositivos não conformes em uma VLAN de remediação/quarentena com alcance restrito. A contabilização apenas registra sessões, a segurança de porta limita endereços MAC e o EAP-TLS é o método de autenticação de identidade, não de integridade do dispositivo.

Questão 4: Alternativa B — Configurar segurança de porta com um número máximo de endereços MAC nas portas de acesso

A segurança de porta restringe quantos endereços MAC de origem distintos podem aparecer em uma porta. Quando o máximo configurado é excedido, o switch pode desativar a porta ou descartar os endereços em excesso, o que neutraliza o cenário do mini-switch em cascata. O EAP-TLS só autentica endpoints corporativos que possuem supplicant, a contabilização apenas registra atividade, e mover os pontos para uma VLAN de convidados ainda deixa as portas abertas a dispositivos não autorizados.

Questão 5: Alternativa A — EAP-TLS

O EAP-TLS exige certificados tanto no cliente quanto no servidor, proporcionando autenticação mútua e uma troca de chaves forte sem transmitir senhas. PEAP e EAP-TTLS usam apenas certificado do lado do servidor e então tunelam um método interno de autenticação geralmente baseado em senha; o EAP-MD5 não oferece autenticação mútua nem derivação de chave e é considerado obsoleto; o LEAP é um método legado proprietário da Cisco com vulnerabilidades conhecidas.

Questão 6: Alternativa C — Autorização

A autorização determina o que um principal autenticado tem permissão de fazer. Atribuição de VLAN, ACLs baixáveis, timeouts de sessão e atributos de papel retornados pelo RADIUS após a verificação de identidade são todas decisões de autorização. A autenticação estabelece a identidade, a contabilização registra a atividade da sessão para revisão posterior, e a auditoria é a revisão separada desses registros, não uma função AAA em tempo de execução.

Questão 7: Alternativa A — EAPOL

O EAPOL (EAP over LAN) é o encapsulamento de Camada 2 definido pelo IEEE 802.1X para o segmento entre supplicant e autenticador. O autenticador termina o EAPOL e então reempacota o payload EAP em pacotes RADIUS para o servidor de autenticação. RADIUS, TACACS+ e LDAP atuam no lado servidor da troca e não são o transporte usado no enlace entre endpoint e switch.

Questão 8: Alternativa D — Implantar 802.1X com autenticação baseada em certificados nas portas de acesso

O 802.1X baseado em certificados vincula o acesso à porta a uma identidade que o atacante não consegue replicar editando um endereço MAC, pois o dispositivo malicioso não consegue completar a troca EAP-TLS sem um certificado de cliente válido. O aprendizado de MAC sticky apenas fixa o primeiro MAC visto na porta; como o atacante apresenta esse mesmo MAC, nenhuma violação é disparada. Aumentar o limite de MACs enfraquece a política, e o DHCP snooping apenas protege contra servidores DHCP falsos e associações DHCP forjadas.

Questão 9: Alternativa B — Contabilização

A contabilização é o componente AAA que registra a atividade da sessão: quem se conectou, de onde, em qual porta ou dispositivo, quando a sessão começou e terminou e, por vezes, quanto de dados foi transferido. Esses registros alimentam relatórios de conformidade e investigações forenses. Autenticação e autorização são decisões em tempo real tomadas durante a tentativa de conexão, enquanto a avaliação de postura verifica a integridade do endpoint.

Questão 10: Alternativa B — Configurar MAC Authentication Bypass nas portas de switch usadas por esses dispositivos

O MAC Authentication Bypass permite que o switch envie o endereço MAC do endpoint ao servidor RADIUS como credencial para dispositivos que não executam supplicant, e os atributos de autorização do RADIUS então colocam o dispositivo na VLAN restrita correta. É mais fraco que o 802.1X baseado em certificados, portanto deve ser combinado com segurança de porta, listas de permissão de MAC e segmentação. Desabilitar o 802.1X deixa as portas abertas, o firmware não aceita EAP-TLS e um limite de MAC zero bloquearia o dispositivo por completo.